

AI risk register

AI-enabled recruitment screening

PURPOSE OF THIS DOCUMENT

Turn the adverse impacts from Document 2 into 12 owned and scored risks, each with a treatment, an approval gate and the evidence that shows it is done.

Document control	Detail
Organisation	Gulf Professional Services PJSC (fictional)
Use case ID	AI-UC-001
Register ID	AIRR-001
Register status	Initial / pre-deployment
Business owner	Chief Human Resources Officer
Risk coordinator	AI Governance Lead
Version and date	Version 1.0 17 September 2026
Source assessment	Document 2: AI Impact Assessment
Prepared by	Tarunima Vijay

1. Risk overview

CURRENT RISK POSITION

Before controls, 3 of the 12 risks are Critical (unfair ranking, over-reliance on AI rankings and misuse of applicant data, each scored 20) and the other 9 are High. With the planned treatments, the target for all 12 is Medium or Low, as tracked in the Excel register. Scores are my judgement on the stated facts and would need checking against real vendor evidence.

Theme	Management observation
Concentration of risk	Most risks share one root cause: the tool influences who is considered for a job, and no vendor evidence or safeguards exist yet.
Immediate focus	The three Critical risks (AI-R-001, AI-R-003, AI-R-004) come first and, under the rules in Section 5, go to the governance forum. Eight treatments are due before pilot approval, three before contracting or system integration, and one before production.
Target position	A human making the final decision is not, by itself, a reason to accept a risk. Acceptance needs evidence that the controls work in the live recruitment process.
Working tool	The Excel register is the working version. It adds causes, consequences, target scores and status for each risk.

2. Rating methodology

Measure	Scale	Interpretation
Likelihood	1 to 5	1 = Rare; 2 = Unlikely; 3 = Possible; 4 = Likely; 5 = Almost certain

Impact	1 to 5	1 = Insignificant; 2 = Minor; 3 = Moderate; 4 = Major; 5 = Severe
Score	Likelihood × Impact	1–5 Low; 6–11 Medium; 12–19 High; 20–25 Critical
Inherent risk	Before proposed treatment	Represents exposure assuming safeguards are absent or not evidenced.
Residual target	After treatment operates	Desired level, subject to evidence, testing and authorised acceptance.

3. Prioritised risk register

Risk ID	Domain	Risk event	Inherent score	Accountable owner	Status
AI-R-001	Fairness	Candidate ranking systematically disadvantages one or more groups	4 × 5 = 20 Critical	CHRO / Recruitment Lead	Open
AI-R-002	Accuracy & Validity	CV details are extracted or scored incorrectly	4 × 4 = 16 High	Model Risk / Analytics Lead	Open
AI-R-003	Human Oversight	Recruiters over-rely on AI scores or rankings	4 × 5 = 20 Critical	Recruitment Lead	Open
AI-R-004	Privacy	Applicant data is used, retained or shared beyond necessity	4 × 5 = 20 Critical	Privacy Officer	Open
AI-R-005	Transparency	Applicants or reviewers do not understand AI use, limitations or rationale	4 × 4 = 16 High	HR Legal Lead	Open
AI-R-006	Accessibility & Inclusion	System design disadvantages non-standard CVs or applicant circumstances	3 × 5 = 15 High	Recruitment Lead	Open
AI-R-007	Security & Resilience	Candidate data or system outputs are exposed, altered or manipulated	3 × 5 = 15 High	Information Security Lead	Open
AI-R-008	Third Party	Vendor changes model, data, features or thresholds without adequate review	4 × 4 = 16 High	Technology Owner / Procurement	Open
AI-R-009	Governance & Accountability	Ownership, approvals or escalation responsibilities are unclear	3 × 4 = 12 High	AI Governance Lead	Open
AI-R-010	Monitoring & Drift	Performance or group outcomes deteriorate after deployment	4 × 4 = 16 High	AI Governance / Model Risk	Open
AI-R-011	Contestability	Applicants cannot correct data or obtain meaningful human reconsideration	3 × 5 = 15 High	HR Operations / Legal	Open
AI-R-012	Purpose & Scope	System is used beyond the approved recruitment-screening purpose	3 × 5 = 15 High	CHRO / Technology Owner	Open

4. Risk treatment plan

Risk ID	Current control position	Required treatment	Target date / gate	Required evidence
AI-R-001	None evidenced	Representative dataset review; feature and proxy analysis; subgroup outcome tests; approved thresholds; remediation and periodic monitoring	Before pilot approval	Fairness tests, approvals and remediation log
AI-R-002	Human review is planned but not yet designed	Job analysis; benchmark validation; error analysis; confidence flags; correction route; periodic sampling	Before pilot approval	Validation report and error log
AI-R-003	Final decision is assigned to a human recruiter	Oversight SOP; independent review prompts; override and stop-use authority; training; override monitoring	Before pilot approval	SOP, training, override logs
AI-R-004	Standard recruitment privacy process to be confirmed	Privacy assessment; purpose limitation; minimisation; retention and deletion; access controls; vendor data restrictions	Before contracting	Privacy assessment and retention evidence
AI-R-005	None evidenced	Candidate notice; reviewer instructions; reason information; limitations; contact and human-reconsideration route	Before pilot approval	Notice, instructions and complaint process
AI-R-006	Alternative route not yet confirmed	Accessibility testing; inclusive design review; alternative submission and accommodation; outcome monitoring	Before pilot approval	Accessibility test and accommodation procedure
AI-R-007	Enterprise controls to be confirmed	Security assessment; least privilege; encryption; logging; resilience testing; incident response; supplier security obligations	Before integration	Security assessment and test results
AI-R-008	Vendor not selected	Due diligence; contract controls; change notification; version records; audit evidence; revalidation and exit plan	Before contracting	Due diligence, contract and change records
AI-R-009	Use case and impact records identify proposed owners	Approved RACI; governance forum; risk acceptance authority; escalation and reassessment triggers	Before pilot approval	RACI, decision record and minutes
AI-R-010	No production monitoring exists	KPIs; subgroup outcomes; drift and override thresholds; review cadence; escalation and stop-use criteria	Before production	Monitoring plan, dashboard and review records
AI-R-011	General recruitment contact route to be confirmed	Correction and complaint workflow; service levels; human reconsideration; decision and response records	Before pilot approval	Workflow, case log and response records
AI-R-012	Prohibited uses identified in registration	Approved intended and prohibited uses; access restrictions; change approval; audit logs and user training	Before pilot approval	Purpose statement, permissions and logs

5. Escalation and acceptance rules

Trigger	Required response
Critical inherent or residual risk	Escalate to the authorised governance forum; do not launch or continue use without explicit decision and documented rationale.
High residual risk	Return for further treatment or require senior risk acceptance within the organisation's risk appetite.
Control failure, incident or material complaint	Assess harm, pause or restrict use where appropriate, investigate, remediate and reassess the affected risks.
Material system, data, vendor or purpose change	Reopen the use case, impact assessment and relevant risks before the change is approved.
Missed treatment date	Escalate to the accountable owner and governance forum; record revised action and rationale.

6. Management responsibilities

Role	Responsibility
Risk owner	Own the exposure, approve treatment, monitor indicators and escalate when thresholds are breached.
Action owner	Deliver the assigned treatment and provide evidence by the agreed date.
AI Governance Lead	Maintain the register, challenge ratings, coordinate reviews and report portfolio-level themes.
Independent validator	Assess whether performance, fairness and other technical safeguards are suitably designed and evidenced.
Authorised governance forum	Approve, return or reject the use case and formally accept residual risk where permitted.

NEXT ARTEFACT

Document 4, the Regulatory Applicability Assessment, uses this register to work out which legal obligations apply. It does not replace the register, which remains the working record.

Portfolio note

Fictional case study prepared for my AI governance portfolio. Scores, owners and gates are my judgement on the stated facts. The method follows ISO/IEC 42001 clauses 6.1.2 (AI risk assessment) and 6.1.3 (AI risk treatment); a real register would use the organisation's own risk methodology and appetite.